BooX

Framework aberto de gestão de risco operacional e controles internos para instituições financeiras brasileiras

Manual de uso, parametrização e fundamentação metodológica

Documento: Versão 1.0 · 13 de novembro de 2026

Canônico: v1.1.1 · **Framework:** v0.2 · **Licenças:** MIT (código) · CC BY 4.0 (dados)

Repositório: github.com/walterCNeto/BooX · **Demonstração:**

booxrisks.streamlit.app

Autor: Walter C. Neto

RESUMO

Este documento descreve o *BooX*, um framework aberto de gestão de risco operacional e controles internos projetado para instituições financeiras brasileiras sujeitas às resoluções *CMN* 4.557/2017 e normas correlatas. O framework organiza o ecossistema de risco em *Books* interligados — processos, riscos, controles, apontamentos, indicadores e sinais externos — e deles deriva um mapa bidimensional de prioridade de tratamento em que o eixo horizontal representa o *ambiente de controles* observado, em substituição à estimativa de probabilidade tradicionalmente utilizada em frameworks de GRC. A arquitetura adota uma camada canônica fixa, um dicionário de tradução (*B_MAP*) e uma camada local preservada no vocabulário próprio do banco, o que permite o reaproveitamento das taxonomias existentes sem reescrita. O manual descreve a fundamentação teórica, a parametrização passo a passo de cada Book, a metodologia de cálculo (com fórmulas e pesos explícitos), a análise de gap regulatório com testes rastreados ao Programa de Qualificação Operacional da BSM, e as premissas assumidas. O conjunto resulta em uma ferramenta auditável, reproduzível e extensível, cuja adoção é compatível com os três níveis de implantação previstos: uso pessoal do analista, ferramenta de área de segunda linha, ou componente de uma arquitetura corporativa de GRC.

Palavras-chave: risco operacional; controles internos; CMN 4.557; RCSA; BSM PQO; framework aberto; 20-box; gap regulatório.

Sumário

1. Introdução

1.1 Contexto regulatório brasileiro

1.2 Lacuna e contribuição

1.3 Público e escopo deste manual

2. Fundamentação teórica

2.1 Três linhas de defesa

2.2 Taxonomia de risco (Basileia, Pilar 3)

2.3 RCSA e a cadeia IPSO

2.4 Por que Impacto × Ambiente, e não Impacto × Probabilidade

3. Arquitetura do framework

3.1 Visão geral

3.2 Camadas canônica e local, e o papel do B_MAP

3.3 Os nove Books do BooX Lite

3.4 A cadeia hierárquica Processo → Teste

4. Metodologia de cálculo

4.1 Eixo Y — impacto inerente

4.2 Eixo X — ambiente de controles

4.3 Cobertura como terceira dimensão

4.4 Matriz de prioridade de tratamento

4.5 Decisões pendentes

4.6 Inferência por moldura regulatória

5. Parametrização passo a passo

5.1 Preparação da instância

5.2 Preenchimento dos Books

5.3 Construção do B_MAP

5.4 Execução e interpretação

6. Catálogo regulatório e análise de gap

6.1 Modelo de catálogo canônico de testes

6.2 Piloto BSM PQO: método de extração

6.3 Resultados e leitura do gap

7. Premissas assumidas e limitações

8. Extensão, governança e curadoria do canônico

9. Referências

Anexo A — Esquema dos CSVs

Anexo B — Enums válidos

Anexo C — Comandos de linha de comando

1. Introdução

1.1 Contexto regulatório brasileiro

A gestão de risco operacional em instituições financeiras brasileiras é orientada por um conjunto articulado de normas. A Resolução CMN 4.557 (CMN, 2017a) estabelece a estrutura de gerenciamento contínuo e integrado de riscos e capital, consolidando em um único instrumento os requisitos antes dispersos para risco de crédito, mercado, liquidez e operacional. A Resolução CMN 4.943 (CMN, 2021a) trata do sistema de controles internos. A Resolução CMN 4.893 (CMN, 2021b) disciplina a política de segurança cibernética e os requisitos para contratação de serviços de processamento e armazenamento em nuvem. A Resolução CMN 4.860 (CMN, 2020) trata do componente organizacional de Ouvidoria. Em domínios adjacentes, a Lei 9.613 (Brasil, 1998) e a Circular BCB 3.978 (BCB, 2020) regem o tema de prevenção à lavagem de dinheiro no SFN, enquanto a Lei Geral de Proteção de Dados Pessoais (Brasil, 2018) governa o tratamento de dados pessoais. No mercado de valores mobiliários, as Resoluções CVM 30, 32, 35 e 50 (CVM, 2021a–d) e, no âmbito autorregulatório, o Programa de Qualificação Operacional administrado pela BSM (BSM, 2025) detalham requisitos operacionais aos Participantes.

Esses instrumentos compartilham um esqueleto comum: todos exigem que a instituição mantenha estrutura de governança proporcional ao seu porte, identifique e avalie seus riscos, implemente controles com efetividade verificada, monitore indicadores, documente apontamentos e os remedie em prazos definidos. A implementação prática dessa disciplina, contudo, encontra duas dificuldades operacionais recorrentes: a fragmentação das ferramentas de GRC adotadas por cada área e a ausência de um vocabulário comum que permita comparar instituições ou agregar informação entre linhas de defesa.

1.2 Lacuna e contribuição

Soluções comerciais de GRC (*Governance, Risk and Compliance*) oferecem interfaces maduras, porém são tipicamente opacas em termos de método: a lógica de pontuação de risco, os pesos atribuídos a cada fonte de sinal e a classificação final não são acessíveis ao auditor independente, e a interoperabilidade entre instituições é limitada pela inexistência de um padrão de taxonomia. No outro extremo, soluções caseiras em planilhas eletrônicas, embora transparentes, raramente resistem à auditoria porque não possuem versionamento disciplinado, validação de integridade referencial ou separação clara entre o vocabulário local da casa e o conceito regulatório canônico.

O BooX propõe-se a ocupar esse espaço intermediário. Como framework aberto, oferece: (i) uma camada canônica versionada e auditável, com riscos ancorados em categorias de uso recorrente no mercado brasileiro; (ii) um dicionário explícito de tradução (*B_MAP*) que preserva o vocabulário local do banco e evita a reescrita do RCSA existente; (iii) uma engine de cálculo transparente, com fórmulas e pesos legíveis em código Python padrão, sem dependências externas; e (iv) um catálogo de testes regulatórios com rastreamento item a item à norma originária, inaugurado pelo piloto de extração do Capítulo 1 do Roteiro PQO 2025 da BSM. A auditabilidade é o critério central do desenho: cada score é reproduzível, cada classificação é explicável, e cada ponte entre o local e o canônico é registrada com autoria e data.

1.3 Público e escopo deste manual

Este documento dirige-se ao analista de risco operacional ou de controles internos que deseja parametrizar o BooX com os dados de sua própria instituição. O conteúdo é organizado para permitir uso em três situações: leitura sequencial por quem se aproxima do framework pela primeira vez; consulta pontual ao Anexo A por quem já conhece a arquitetura e precisa apenas da referência de campos; e fundamentação metodológica por quem precisa defender o emprego do framework junto à auditoria, à superintendência de risco ou à segunda linha de compliance. As Seções 1 a 4 cobrem fundamentação e método; as Seções 5 e 6 descrevem a parametrização e a análise de gap regulatório; as Seções 7 a 9 tratam de limitações, extensão e governança. Os Anexos A, B e C oferecem referência técnica consolidada.

2. Fundamentação teórica

2.1 Três linhas de defesa

O modelo das três linhas de defesa, formalizado pelo *Institute of Internal Auditors* em 2013 e revisto em 2020 (IIA, 2020), distribui responsabilidades de risco em camadas complementares. A primeira linha é composta pelas áreas de negócio e operação, que são proprietárias dos riscos que geram e dos controles de primeira linha que mitigam esses riscos. A segunda linha compreende as funções de risco, conformidade e controles internos, com atribuição de desenho, monitoramento independente e consolidação. A terceira linha é exercida pela auditoria interna, que avalia de forma independente a efetividade das duas linhas anteriores. O modelo pressupõe segregação funcional e reporte independente da segunda e da terceira linhas à alta administração.

A taxonomia organizacional canônica do BooX distribui as 73 áreas pré-cadastradas entre as três linhas, conforme o papel típico: as áreas de Negócios, Crédito, Tecnologia da Informação, Operações e Tesouraria compõem a primeira linha; as áreas de Riscos, Controles Internos e Compliance, e Jurídico ocupam a segunda; Auditoria Interna, Ouvidoria, Financeiro, Recursos Humanos e Fornecedores integram a terceira linha ou funções de apoio. Essa distribuição é documental e serve como referência, podendo ser ajustada por banco por meio do dicionário de tradução.

2.2 Taxonomia de risco: Basileia e divulgação de Pilar 3

A taxonomia canônica de riscos do BooX adota como ponto de partida as categorias amplas consolidadas pelo Comitê de Basileia (BCBS, 2021a; BCBS, 2021b) e pela prática de divulgação de Pilar 3. Os 20 riscos de nível zero (R0) cobrem as seguintes categorias: crédito, mercado, liquidez, taxa de juros do *banking book* (IRRBB), variação cambial, operacional, cibernético, modelo, resiliência e continuidade, fornecedores e terceiros, conformidade, conduta, lavagem de dinheiro e financiamento ao terrorismo, privacidade e proteção de dados, reputacional, negócio e estratégia, país, contágio, socioambiental e climático, e riscos emergentes. A categoria de riscos emergentes é mantida explicitamente para admitir conceitos cuja materialidade ainda está sendo observada, como a extensão R0.U.21 adicionada em maio de 2026 para riscos associados a modelos de inteligência artificial generativa.

A granularidade do catálogo é estendida até o nível R4 para conceitos operacionais testáveis. A árvore de descendência, por exemplo, para o risco cibernético é R0.U.7 → R1.U.7.1 (falha de controle de acesso) → R2.U.7.1.1 (credencial privilegiada exposta) → R3.U.7.1.1.1 (compartilhamento de credencial de administrador) → R4.U.7.1.1.1.1 (credencial admin sem MFA em sistema crítico). O nível R4 corresponde ao caso específico e verificável, para o qual pode haver teste canônico associado, controle esperado e evidência documental.

2.3 RCSA e a cadeia IPSO

O *Risk and Control Self-Assessment* (RCSA) é o instrumento primário pelo qual a primeira linha documenta, em protocolo estruturado, os riscos inerentes aos seus processos e a avaliação de eficácia dos controles existentes. A documentação de processos adota com frequência a convenção IPSO: Input, Process,

Service e Output. Essa convenção fornece uma linguagem comum para descrever qualquer processo de maneira agnóstica ao setor, permitindo encadear processos de nível P0 (macroprocessos institucionais) a processos de nível P4 (atividades operacionais específicas e testáveis).

O BooX adota essa hierarquia como estrutura do Book de processos (B1). Cada processo possui um identificador único, um nível hierárquico (0 a 4), uma área responsável, e opcionalmente uma criticidade do tipo Business Impact Analysis (BIA) em escala discreta de 1 a 5. O controle 5W2H dos controles mitigadores (Book B5) é tratado como extensão opcional: os campos *what* (ação), *why* (risco mitigado) e a eficácia autoavaliada são obrigatórios; os demais elementos do 5W2H (*who*, *where*, *when*, *how*, *how much*) são recomendados e sua ausência rebaixa a confiança da avaliação.

2.4 Por que Impacto × Ambiente, e não Impacto × Probabilidade

A matriz Impacto × Probabilidade é o instrumento clássico de avaliação de risco em projetos a priori, nos quais não há série histórica do evento de interesse e a estimativa de probabilidade é necessariamente subjetiva. Para processos em operação contínua, com dados acumulados de apontamentos, indicadores, reclamações procedentes e perdas materializadas, a estimativa de probabilidade torna-se ora redundante — pois coincide com a frequência observada — ora contraproducente, pois descarta a evidência em favor de opinião.

O regime regulatório brasileiro, articulado por CMN 4.557 (CMN, 2017a) e normas correlatas, assume monitoramento empírico contínuo e trata a evidência como insumo primário da avaliação. O BooX incorpora essa premissa substituindo o eixo horizontal da matriz pela agregação multidimensional do *ambiente de controles* observado. A agregação combina apontamentos abertos (por severidade e origem), o déficit da eficácia dos controles (ponderado pelo grau de validação independente) e a cobertura da avaliação, conforme detalhado na Seção 4. A matriz Impacto × Probabilidade não é descartada: permanece como instrumento adequado para riscos emergentes sem histórico e para riscos de cauda em estudos de cenários; mas não é usada como base de avaliação cotidiana dos processos vivos.

Essa substituição implica uma consequência prática relevante: um banco que não tenha evidência (apontamentos, indicadores, validações) para determinado par processo–risco não deve receber classificação favorável por ausência de dado. A falta de evidência não é tratada como ausência de problema, mas como ausência de avaliação, e essa distinção é materializada na dimensão de cobertura introduzida na Seção 4.3.

3. Arquitetura do framework

3.1 Visão geral

O BooX é organizado em três estratos. O estrato *canônico*, versionado e comum a todas as instalações, contém as taxonomias de organização, riscos e disciplinas, bem como o catálogo canônico de testes regulatórios. O estrato *local*, próprio de cada banco, contém os Books com as entidades operacionais da casa — processos, riscos locais, controles, apontamentos, indicadores, sinais externos, visões analíticas e execução de testes. O estrato de *tradução*, materializado no Book *B_MAP*, estabelece a correspondência entre os identificadores locais e os identificadores canônicos.

A engine de cálculo, implementada em Python padrão e sem dependências externas na camada *core*, lê os Books locais, consulta as traduções do B_MAP, computa as coordenadas de cada par processo–risco e produz quatro artefatos: o mapa visual (20-box), o detalhamento em CSV, o parecer textual e o diagnóstico de suficiência dos dados. A engine de gap regulatório, em módulo apartado, cruza os testes canônicos aplicáveis ao tipo de instituição com os testes efetivamente executados pela casa.

3.2 Camadas canônica e local, e o papel do B_MAP

A separação entre canônico e local resolve a tensão entre padronização e preservação do vocabulário interno. O banco não é obrigado a reescrever sua taxonomia de riscos ou de áreas para adotar o BooX; mantém os seus identificadores, as suas siglas e os seus nomes comerciais, e declara, no B_MAP, o identificador canônico correspondente a cada termo local. A consulta ao B_MAP é feita pela engine no momento do cálculo, e apenas mapeamentos com status *aprovado* ou *ajustado* são admitidos.

Essa separação é também o ponto natural de intervenção humana no caso de uso assistido por inteligência artificial. Quando uma rotina de IA é empregada para propor correspondências, a proposta não substitui o mapeamento oficial: é gravada com status *sugerido*, acompanhada da métrica de similaridade e da indicação do método (match exato, similaridade por embeddings ou classificação restrita por LLM), e aguarda revisão por um responsável humano. O controle é institucional: o BooX nunca admite a criação de um identificador canônico pela IA — apenas a escolha entre identificadores previamente catalogados.

3.3 Os nove Books do BooX Lite

A configuração padrão do BooX, denominada *Lite*, utiliza nove Books principais, descritos a seguir. Cada Book é um arquivo CSV com separador ponto-e-vírgula, codificação UTF-8 e cabeçalho na primeira linha. Os identificadores são textuais e a integridade referencial entre Books é checada pela engine de suficiência.

Tabela 1 — Books do BooX Lite e suas finalidades.

Book	Finalidade	Registros no Banco Modelo
B1 Processos	Catálogo hierárquico de processos P0 a P4	28
B6 Riscos (taxonomia)	Riscos no vocabulário local, mapeados a R0 canônicos via B_MAP	17
B6 Vínculo Processo×Risco	Pares avaliáveis, com materialidade inerente — base de cada bolha	34
B5 Controles	Controles mitigadores em protocolo 5W2H estendido	20
B2 Apontamentos	Risco materializado: apontamentos abertos com severidade, prazo, afetada e gestora	23
B10 Indicadores (KRIs)	Definição dos KRIs com limiares amarelo e vermelho	16
B10 Série temporal	Valores mensais que alimentam tendência e status	96
B8 Externos	Sinais externos públicos e manifestações de clientes (Ouvidoria, SAC)	14
B9 Disciplinas	Dimensão transversal de corte (crédito, cyber, PLD etc.)	15
B4 Regulação (opcional)	Normas aplicáveis e vínculo com processos ou riscos	8
B7 Visões	Recortes analíticos (por produto, por disciplina, por área, E2E)	5

A versão atual do catálogo canônico inclui ainda dois Books canônicos adicionais, *B_FR* (fatores de risco) e *B_TESTES*, e dois Books locais associados, *B_TESTES_execucao* e *B_EVIDENCIA*, descritos na Seção 3.4 e na Seção 6.

3.4 A cadeia hierárquica Processo → Teste

A cadeia regulamentar introduzida na Fase 1 do BooX conecta o nível mais agregado (processo) ao nível mais granular e testável (evidência documental). Os seis níveis da cadeia são:

1. **Processo:** hierarquia P0 → P4, no vocabulário do banco (B1).
2. **Risco R4:** extensão granular do risco canônico, no nível em que faz sentido testar.
3. **Fator de Risco (FR):** causa-raiz específica do risco, catalogada em B_FR.
4. **Controle esperado:** o controle que a norma exige que exista, conforme catálogo canônico de testes.
5. **Teste:** procedimento de verificação do funcionamento do controle (B_TESTES_canonico).
6. **Evidência:** artefato que comprova o atendimento ao teste (B_EVIDENCIA).

A cadeia permite respostas analíticas que seriam difíceis em uma estrutura plana. Para um dado requisito do PQO, é possível identificar o controle esperado, verificar se o banco possui controle real equivalente, consultar a evidência da última execução do teste e inspecionar a existência de apontamentos abertos sobre

aquele controle. A partir do mesmo encadeamento, é possível identificar fatores de risco sem controle real mapeado — denominados fatores descobertos — como sinal estrutural de vulnerabilidade.

4. Metodologia de cálculo

Cada par processo–risco declarado em *B6 Vínculo* recebe duas coordenadas numéricas que determinam sua posição no mapa visual e sua prioridade de tratamento. Uma terceira dimensão, a cobertura, modula graficamente a representação da bolha sem alterar a posição, comunicando o grau de confiança da avaliação. Esta seção apresenta as fórmulas, pesos e cortes adotados.

4.1 Eixo Y — impacto inerente

O eixo Y é a projeção direta da materialidade inerente declarada pelo responsável do par, em escala discreta de 1 (imaterial) a 5 (elevado). A conversão para a escala contínua do mapa segue o esquema de pontos médios, como mostra a Tabela 2. O nível categórico é determinado pelo valor contínuo arredondado para baixo, de modo a preservar a correspondência com a escala original declarada.

Tabela 2 — Mapeamento materialidade declarada → escala contínua Y.

Materialidade	Nível categórico	Score Y (ponto médio)
1	Imaterial	0,500
2	Baixo	1,500
3	Médio	2,500
4	Alto	3,500
5	Elevado	4,500

4.2 Eixo X — ambiente de controles

O eixo X mede a qualidade do ambiente de controles do par e é definido como uma agregação multidimensional limitada ao intervalo [0, 100], em que valores altos indicam ambiente pior. A fórmula agregadora é:

$$score_X(p,\, r) = f_{apont}(p,\, r) + f_{ctrl}(p,\, r) + f_{cob}(p,\, r) \quad \text{(Eq. 1)}$$

A componente de apontamentos, f_{apont}, acumula os pesos associados a cada apontamento aberto no par, com fator multiplicativo pela origem e pela situação de prazo, limitada a um teto de 45 pontos. A Tabela 3 apresenta os pesos adotados. A componente de controles, f_{ctrl}, é derivada do déficit médio de eficácia dos controles declarados para o par: parte de uma eficácia máxima de 5 e subtrai a eficácia efetiva. Quando o par não possui controle declarado, atribui-se um valor base de 18 pontos, equivalente a um déficit médio de 3 unidades (limiar entre neutro e atenção), como penalidade por ausência de informação. A componente de cobertura, f_{cob}, aplica penalidade adicional de 8 pontos quando o par não possui nenhum sinal declarado — nem apontamento, nem controle — consolidando a diretriz de que a ausência de evidência não é tratada como ausência de problema.

Tabela 3 — Pesos aplicados aos apontamentos abertos na componente f_{apont}.

Severidade	Peso base	Fator origem	Ajuste prazo
Crítico	4,000	× 2 se regulador	+ 1,500 se vencido
Alto	2,000		
Médio	1,000		
Baixo	0,500		

A eficácia dos controles combina, para cada controle declarado, a autoavaliação da primeira linha e a validação independente da segunda linha, segundo pesos relacionados ao grau de validação, conforme a Tabela 4. Essa ponderação implementa a *cobertura de transição*: quanto mais forte a validação independente, menor o peso atribuído à autoavaliação e, portanto, maior a confiabilidade atribuída ao número que entra na fórmula.

Tabela 4 — Pesos da autoavaliação (p_a) e da validação independente (p_v) em função do status.

Status de validação	p_a	p_v
Apenas autoavaliado	1,000	0,000
Validado documentalmente	0,700	0,300
Validado por amostra	0,400	0,600
Validado completo	0,100	0,900

A conversão do $score_X$ contínuo nos cinco níveis categóricos do eixo X segue cortes uniformes em intervalos de 20 pontos, apresentados na Tabela 5. Essa discretização é a que determina a célula do mapa onde a bolha é posicionada.

Tabela 5 — Discretização do eixo X.

Intervalo de $score_X$	Rótulo	Nível categórico
[0, 20)	++	Adequado
[20, 40)	+	Bom
[40, 60)	0	Neutro
[60, 80)	−	Atenção
[80, 100]	−−	Crítico

4.3 Cobertura como terceira dimensão

A cobertura é definida, para cada par processo–risco, como a média aritmética dos pesos de validação independente dos controles declarados para o par, na escala percentual apresentada na Tabela 6. Pares sem controle declarado recebem cobertura igual a zero. Essa definição corresponde à *Interpretação A* discutida na fase de desenho do framework: cobertura reflete validação, e não simplesmente a presença de dados.

Tabela 6 — Conversão do status de validação em percentual de cobertura.

Status	Cobertura (%)
Sem controle declarado	0,000
Apenas autoavaliado	25,000
Validado documentalmente	50,000
Validado por amostra	75,000
Validado completo	100,000

A representação visual da cobertura é incorporada à bolha do par: a parcela preenchida em preto é proporcional ao percentual de cobertura, e a parcela em cinza claro corresponde à fração não coberta. A posição da bolha no mapa não é afetada pela cobertura; apenas a confiança comunicada ao leitor se altera. Essa dissociação é deliberada: evita que um ambiente aparentemente favorável, sustentado por autoavaliação sem validação, seja confundido com um ambiente validado.

4.4 Matriz de prioridade de tratamento

A combinação do nível categórico de impacto com o nível categórico de ambiente define a prioridade de tratamento, segundo a matriz 5×5 apresentada na Tabela 7. A matriz foi desenhada com dois princípios: monotonia em cada eixo (prioridade não piora quando o impacto diminui, nem quando o ambiente melhora) e rebaixamento controlado da classificação para o canto seguro (impacto elevado nunca é classificado abaixo de médio, mesmo em ambiente adequado).

Tabela 7 — Matriz de prioridade de tratamento (linhas: impacto; colunas: ambiente).

	−− Crítico	− Atenção	0 Neutro	+ Bom	++ Adequado
Elevado	Crítico	Crítico	Alto	Médio	Médio
Alto	Crítico	Alto	Médio	Médio	Baixo
Médio	Alto	Médio	Médio	Baixo	Baixo
Baixo	Médio	Médio	Baixo	Baixo	OK
Imaterial	Médio	Médio	Baixo	Baixo	OK

4.5 Decisões pendentes

O framework adota como premissa metodológica que todo problema concreto identificado — seja por indicador no vermelho, por sinal externo relevante ou por reclamação procedente — deve ser formalizado como apontamento, com plano de ação e responsável. Indicadores e sinais externos, portanto, não entram diretamente no $score_X$ como componentes somáveis; em vez disso, a engine identifica os sinais que não possuem apontamento associado e os lista como *decisões pendentes*: cada item representa uma escolha a ser tomada pela casa — abrir apontamento ou justificar explicitamente a não abertura.

A regra atual classifica como relevantes, para fins de decisão pendente: indicadores com status vermelho ou amarelo; procedentes de BACEN, Procon ou Ouvidoria em quantidade igual ou superior a cinco no período; processos sancionadores da CVM com qualquer quantidade; recomendações ANBIMA; matérias de mídia com severidade igual ou superior a quatro; e solicitações de SAC não resolvidas em quantidade igual ou superior a vinte. A lista é consumida pela interface e pelo parecer gerado, não pelo cálculo do score.

4.6 Inferência por moldura regulatória

A análise de controles internos no módulo de gap regulatório diferencia três estados possíveis para cada controle declarado: *mapeado*, quando o controle está associado explicitamente a um teste canônico por meio de B_TESTES_execucao; *atende por moldura*, quando o controle não possui teste específico associado mas o risco canônico que ele endereça pertence a um domínio normativo bem definido; e *sem moldura*, quando nem o teste específico nem a moldura estão identificados.

A inferência de moldura é determinística e opera sobre o risco canônico associado ao controle, obtido via B_MAP. O mapeamento R0 → norma-moldura consolida as atribuições normativas usualmente aceitas no mercado brasileiro: R0.U.6 (Risco Operacional) e R0.U.11 (Risco de Conformidade) associam-se à CMN 4.557; R0.U.7 (Risco Cibernético) à CMN 4.893; R0.U.13 (Risco de Lavagem de Dinheiro e FT) à Lei 9.613; R0.U.14 (Risco de Privacidade e Proteção de Dados) à LGPD. A inferência não substitui o teste específico quando este existe; apenas evita classificar prematuramente como sem fundamento regulatório um controle legítimo cuja norma de suporte ainda não teve seus requisitos extraídos para o catálogo canônico.

5. Parametrização passo a passo

Esta seção descreve o procedimento de parametrização do BooX para a instituição que deseja usar o framework com seus próprios dados. O procedimento assume que o repositório do BooX está instalado localmente ou que o pacote `boox-ro` foi instalado via gestor de pacotes interno. A sequência recomendada é: preparar a pasta de instância, preencher os Books estruturais (B1 Processos e B6 Riscos), em seguida o vínculo B6, os controles B5 e os apontamentos B2, depois os indicadores B10 e os sinais externos B8, e por fim construir o B_MAP de tradução.

5.1 Preparação da instância

A instância é uma pasta no sistema de arquivos que agrupa os Books do banco. O nome é livre, mas é recomendado que descreva a casa ou o ciclo de avaliação (por exemplo, *banco_x_2026q1*). Dentro da pasta, cada Book é um arquivo CSV com cabeçalho na primeira linha, separador ponto-e-vírgula e codificação UTF-8. Os nomes esperados pela engine são rigorosos e são listados integralmente no Anexo A.

A instância de demonstração *examples/banco_modelo_sa*, distribuída com o repositório, serve como referência estrutural. Ao começar a parametrização, recomenda-se baixar o pacote ZIP com os CSVs da demonstração, disponível na interface Streamlit do framework, abrir os arquivos no editor de planilhas e substituir o conteúdo pelos dados próprios da casa, preservando a estrutura das colunas e os formatos de data (AAAA-MM-DD) e número (ponto como separador decimal).

5.2 Preenchimento dos Books

Cada Book possui três categorias de campos: obrigatórios, recomendados e opcionais. Campos obrigatórios devem estar preenchidos em todos os registros; sua ausência impede o registro de participar do cálculo. Campos recomendados rebaixam a qualidade da avaliação quando ausentes, mas não a impedem; são sinalizados pela engine de suficiência com rebaixamento de status. Campos opcionais enriquecem a documentação e não afetam o cálculo.

B1 — Processos

Cada processo recebe identificador único (prefixo convencional *P* seguido de nível e núcleo), nome, nível hierárquico de 0 a 4, e área responsável (obrigatório). Recomenda-se preencher o identificador do processo pai (*parent_id*, vazio apenas para P0), o núcleo (um dos sete valores enumerados: U universal, B bancário, MC mercado de capitais, S seguros, P previdência, C consórcio, CG consolidado de grupo), e a criticidade BIA em escala 1 a 5. A descrição, inputs e outputs no formato IPSO são opcionais.

B6 — Riscos (taxonomia local)

Cada risco local recebe identificador textual (prefixo convencional *RL-* seguido de número de dois dígitos) e nome. Recomenda-se informar nível hierárquico, identificador do risco pai, e disciplina associada. A categoria Basileia é opcional. O mapeamento ao R0 canônico é feito no B_MAP, não aqui.

B6 Vínculo — Processo × Risco

Cada linha é um par processo–risco avaliável, e corresponde a uma bolha no mapa. Os campos obrigatórios são identificador do processo, identificador do risco e materialidade inerente (1 a 5). Recomenda-se informar o autor da declaração (responsável pela materialidade), sem distinção de afetada e gestora, pois estas pertencem ao mundo materializado tratado no B2.

> ***Nota metodológica.*** A ausência de campos de afetada e gestora no vínculo inerente é deliberada. Risco inerente é construção a priori, sobre processos e riscos abstratos; afetada e gestora só têm sentido quando o risco se materializa em um evento concreto, e portanto pertencem ao apontamento.

B2 — Apontamentos

Os campos obrigatórios do apontamento são identificador, título, severidade (crítico, alto, médio ou baixo), status (aberto, em tratamento, vencido ou fechado), identificador do risco local associado (ou do processo, sendo pelo menos um dos dois obrigatório), data de abertura, área afetada e área gestora. Recomenda-se informar também a origem (controles internos, auditoria, compliance, gestão ou regulador — valor que duplica o peso do apontamento no score), data de prazo, responsável nomeado para a remediação, e recorrência. Para apontamentos fechados, a data de fechamento é opcional mas útil para análise histórica.

B5 — Controles

A ação mitigadora (campo *acao*, correspondente ao *what* do 5W2H) e o risco mitigado (campo *risco_id*, correspondente ao *why*) são obrigatórios, bem como a eficácia autoavaliada em escala discreta de 1 a 5. Fortemente recomendado: processo em que o controle opera, eficácia validada independentemente pela segunda linha, status de validação (apenas autoavaliado, validado documentalmente, validado por amostra ou validado completo), natureza (preventivo, detectivo ou corretivo), frequência e responsável nomeado. Os demais elementos do 5W2H são opcionais mas úteis: local (*where*), mecanismo (manual, semiautomatizado ou automatizado), descrição textual do método (*how*), e cobertura percentual (*how much*).

B10 — Indicadores e série temporal

Cada KRI recebe identificador, nome, direção (menor-melhor ou maior-melhor, obrigatório para a correta interpretação dos limiares) e identificador do risco associado. Recomenda-se informar os limiares amarelo e vermelho, sem os quais o indicador registra a série mas não contribui para alertas de status. A série temporal é um Book separado com três campos obrigatórios por linha: identificador do indicador, competência no formato AAAA-MM e valor. A engine calcula tendência apenas quando há no mínimo três observações.

B8 — Externos, Ouvidoria e SAC

O Book B8 consolida sinais externos públicos e manifestações de clientes. Os campos obrigatórios são identificador, fonte (BACEN, CVM, ANBIMA, Procon, mídia, Reclame Aqui, Ouvidoria ou SAC), tipo (dependente da fonte) e data. Recomenda-se amarrar o sinal ao risco local ou à disciplina para que seja contabilizado no par correto. Para cada fonte, há pesos e tetos específicos, documentados na Seção 4.

B_MAP — Dicionário de tradução

O B_MAP é o Book que faz a ponte entre o vocabulário local e o canônico. Cada linha representa um mapeamento de um termo local para um identificador canônico, com um domínio (risco, área, processo ou disciplina), um método (exato, similaridade, LLM ou manual), um status (sugerido, aprovado, ajustado ou rejeitado), um responsável pela aprovação e uma data de revisão. Apenas mapeamentos com status aprovado ou ajustado são usados pela engine. O B_MAP é tipicamente construído incrementalmente: no primeiro ciclo, a casa mapeia os conceitos mais relevantes; nos ciclos seguintes, a cobertura do mapeamento é expandida.

5.3 Construção do B_MAP

Para cada risco local presente em B6, o B_MAP deve conter uma linha com o identificador do risco e o R0 canônico correspondente. A escolha do R0 segue a categoria predominante do risco local, consultando a lista canônica apresentada no Anexo B. Quando o risco local é específico demais para caber em um R0 único, duas estratégias são possíveis: criar um mapeamento com status *ajustado* e nota explicativa, ou solicitar ao mantenedor do canônico a inclusão de um novo R0 (ou extensão R1–R4), conforme o processo de curadoria descrito na Seção 8.

5.4 Execução e interpretação

Com os Books preenchidos, a execução do framework produz quatro artefatos primários: o mapa visual (*20box.html*), o detalhamento em CSV (*detalhamento.csv*), o parecer textual (*parecer.md*) e o diagnóstico de suficiência (*suficiencia.md*). A análise de gap regulatório é gerada por módulo separado, a partir do mesmo conjunto de Books, com filtro pelo tipo de instituição.

A leitura recomendada começa pelo diagnóstico de suficiência: se há Books ausentes ou se há campos obrigatórios incompletos, os registros afetados não entram no cálculo e o mapa pode estar incompleto. Em seguida, a tabela de pares que exigem tratamento, no parecer, apresenta os pares em prioridade crítica e alta ordenados pelo $score_X$, com justificativa textual de impacto e ambiente. O mapa visual oferece a visão agregada; a tabela de detalhamento permite auditoria quantitativa de cada par; e a lista de decisões pendentes expõe os sinais que aguardam formalização em apontamento.

6. Catálogo regulatório e análise de gap

6.1 Modelo de catálogo canônico de testes

O catálogo canônico de testes (*B_TESTES_canonico*) materializa a exigência regulatória no nível em que pode ser verificada empiricamente. Cada registro contém identificador textual único, regulador emissor, identificador da norma originária, título do teste, aplicabilidade por tipo de instituição, artigo ou item da norma, descrição, método de verificação, evidência esperada, frequência mínima, criticidade, risco canônico associado, fator de risco canônico (opcional), texto do controle esperado, status, data de publicação e URL da fonte oficial.

O status admite três valores: *ativo*, para testes com rastreamento verificado ao texto oficial da norma; *proposto*, para testes incluídos como arcabouço estrutural cujo conteúdo regulatório ainda não foi validado contra a fonte primária; e *deprecado*, para testes substituídos ou revogados. Essa distinção protege o usuário de tratar como referência regulatória conteúdo que foi incluído apenas para demonstrar a estrutura do catálogo.

6.2 Piloto BSM PQO: método de extração

O piloto da Fase 2 do BooX converteu em testes canônicos ativos os 14 itens do Capítulo 1 (Cadastrar Clientes) do Roteiro PQO 2025 da BSM, identificados como *TST.BSM.PQO.CAD.001* a *014*. A extração seguiu um protocolo de fidelidade que separa o que vem do texto literal do PQO do que é interpretação do mantenedor: título, descrição, identificador da norma, artigo e aplicabilidade são preservados do texto oficial; método de verificação, evidência esperada, frequência mínima, criticidade e risco canônico associado são inferências técnicas do mantenedor e devem ser revistas pelo responsável da casa antes de serem adotadas como referência operacional.

A codificação de normas adota identificadores estáveis e legíveis: *RES_CVM_30* para a Resolução CVM 30/2021 (Suitability), *RES_CVM_32* para a 32/2021 (Agentes de Custódia), *RES_CVM_35* para a 35/2021 (Conduta de intermediários), *RES_CVM_50* para a 50/2021 (PLD-FT no mercado de capitais), e assim sucessivamente. Os Ofícios Circulares, Deliberações e Comunicados Externos da CVM e da B3 seguem padrões análogos. Essa codificação é documentada em *docs/fase2_bsm_pqo.md*.

6.3 Resultados e leitura do gap

A análise de gap regulatório cruza os testes canônicos aplicáveis ao tipo de instituição com os testes efetivamente executados pela casa, declarados no Book local *B_TESTES_execucao*. A saída apresenta quatro grupos de resultado: cobertura por regulador (quantidade e proporção de testes atendidos por regulador), requisitos regulatórios não atendidos (todos os testes aplicáveis em estado parcial, não conforme ou sem execução, estratificados por criticidade), controles internos não regulatórios (controles declarados no B5 sem teste canônico associado, classificados por inferência de moldura conforme Seção 4.6) e fatores de risco descobertos (fatores de risco canônicos cujos testes não são atendidos em nenhuma instância, sinal estrutural de vulnerabilidade).

A instância de demonstração do Banco Modelo S.A., quando filtrada pelo tipo *corretora*, apresenta 20 testes aplicáveis (14 do BSM PQO Cap 1 e 6 dos seeds), 16 requisitos não atendidos (8 em criticidade alta e 8 em criticidade média), 15 controles internos sem teste canônico associado (todos classificados como atendem alguma moldura regulatória, dos quais a maioria associada à CMN 4.557), e 5 fatores de risco descobertos. A leitura desses resultados permite priorizar o plano de remediação e orientar a expansão incremental do catálogo canônico de testes.

7. Premissas assumidas e limitações

A adoção do BooX pressupõe aceitação de um conjunto de premissas metodológicas. Este seção torna essas premissas explícitas, permitindo que a instituição avalie a aderência ao seu contexto e, quando necessário, adapte o framework por meio dos pontos de extensão descritos na Seção 8.

Premissa 1 — Evidência precede opinião

Para processos em operação contínua, a avaliação de risco é derivada prioritariamente de evidência observada (apontamentos, indicadores, reclamações procedentes, perdas materializadas), e não de estimativas de probabilidade. Essa premissa está incorporada no eixo horizontal do mapa e é a decisão metodológica central do framework.

Premissa 2 — Ausência de dado é ausência de avaliação, não ausência de problema

Pares sem controle declarado, sem indicador associado e sem apontamento recebem penalidade na componente de cobertura do $score_X$, de modo que o desconhecido não é confundido com o adequado. A cobertura visual de cada bolha (parcela em preto) comunica o grau de confiança da avaliação.

Premissa 3 — Problema concreto vira apontamento

Indicadores no vermelho e sinais externos relevantes não entram diretamente na fórmula do ambiente; apenas os apontamentos abertos o fazem. A existência de um sinal sem apontamento associado é tratada como *decisão pendente*: a casa deve explicitamente abrir apontamento ou justificar a não abertura. Essa premissa transfere ao responsável institucional a decisão sobre a materialidade do sinal, em vez de inferi-la por regra automática.

Premissa 4 — Afetada e gestora pertencem ao mundo materializado

No mundo inerente, a área responsável do par é a área dona do processo. Afetada e gestora são campos do apontamento, pois só fazem sentido quando o risco se materializa em evento concreto que exige remediação com responsável nomeado.

Premissa 5 — Controle validado por terceiro pesa mais que controle autoavaliado

A eficácia efetiva usada no cálculo é a combinação ponderada da autoavaliação da primeira linha e da validação independente da segunda linha, com pesos descritos na Tabela 4. Quanto mais forte a validação independente, menor o peso da autoavaliação. Essa ponderação implementa a cobertura de transição e evita que avaliações exclusivamente autoatribuídas sejam tratadas no mesmo nível de confiabilidade que avaliações validadas.

Premissa 6 — Separação local e canônico

O banco preserva o vocabulário local; a correspondência com o canônico é explícita no B_MAP, com autoria e data. Nenhuma inferência é feita silenciosamente: mapeamentos sugeridos por IA permanecem com status *sugerido* até revisão humana, e a engine utiliza apenas mapeamentos com status aprovado ou ajustado.

Limitações reconhecidas

O BooX, em sua versão atual, apresenta três limitações que merecem registro. Primeiro, o catálogo canônico de testes contém, no momento desta publicação, apenas 14 testes ativos rastreados (BSM PQO Cap 1) e 7 testes seed propostos; a extensão para os demais capítulos do PQO e para outras normas (CMN 4.557 na íntegra, CMN 4.893, BSM PQO Caps 2 a 16) depende de trabalho incremental de extração e validação. Segundo, a análise de suficiência não implementa, no momento, validação de tipos de dados dos campos CSV, limitando-se a verificar presença e integridade referencial; a casa deve garantir a consistência tipográfica dos dados antes da execução. Terceiro, a inferência por moldura regulatória (Seção 4.6) é determinística e não substitui a análise de cada controle caso a caso; sua finalidade é separar o controle legítimo sem teste mapeado do controle sem fundamento regulatório identificável, mas a avaliação final permanece atribuição do responsável pela área.

8. Extensão, governança e curadoria do canônico

A evolução controlada do canônico é condição para a adoção sustentável do framework. Um canônico fixo rapidamente desatualiza-se; um canônico modificável sem controle perde a função de vocabulário comum e quebra retroativamente os mapeamentos existentes. O BooX adota, para esse problema, o protocolo denominado *Rota A*: mudanças aditivas são livres, mudanças destrutivas são proibidas, e em vez de exclusão de um identificador adota-se a *deprecação* com indicação de substituto. O protocolo é materializado por três artefatos: o arquivo *canonico/VERSION* contendo a versão semântica do canônico (atualmente 1.1.1); o arquivo *canonico/CHANGELOG.md* com histórico de mudanças; e o utilitário *canonico/curar.py* que automatiza as operações de adição, renomeação, deprecação e listagem, preservando a integridade referencial e atualizando a versão.

A adição de um novo identificador (por exemplo, um risco canônico inexistente até então) incrementa a versão *minor*; a renomeação de um rótulo ou descrição incrementa a versão *patch*; a deprecação de um identificador em uso incrementa a versão *major*, dada a potencial necessidade de migração dos mapeamentos. Cada operação é registrada automaticamente no changelog com data e autoria. O utilitário *validar.py*, executado após qualquer mudança, verifica a integridade referencial completa do canônico, incluindo a consistência das referências cruzadas entre fatores de risco, testes e riscos.

A extensão do catálogo canônico de testes para novos capítulos do PQO BSM ou para novas normas segue protocolo análogo: cada novo teste é criado com status *proposto* e passa para status *ativo* apenas após validação contra o texto oficial da norma. Os campos de rastreabilidade (*norma_id*, *artigo*, *fonte_url*, *data_publicacao*) são obrigatórios para a transição de status. Essa disciplina permite distinguir, de forma inequívoca, o arcabouço estrutural (proposto) do catálogo verificado (ativo).

9. Referências

BANCO CENTRAL DO BRASIL (BCB). Circular BCB 3.978, de 23 de janeiro de 2020. Dispõe sobre a política, os procedimentos e os controles internos a serem adotados pelas instituições autorizadas a funcionar pelo BCB visando à prevenção à lavagem de dinheiro e à prevenção ao financiamento do terrorismo. Brasília: BCB, 2020.

BANCO CENTRAL DO BRASIL (BCB). Resolução BCB 265, de 25 de novembro de 2022. Dispõe sobre a estrutura e o funcionamento do sistema de gerenciamento continuado e integrado de riscos. Brasília: BCB, 2022.

BASEL COMMITTEE ON BANKING SUPERVISION (BCBS). Principles for operational resilience. Basel: BIS, março 2021a.

BASEL COMMITTEE ON BANKING SUPERVISION (BCBS). Revisions to the principles for the sound management of operational risk. Basel: BIS, março 2021b.

BM&FBOVESPA SUPERVISÃO DE MERCADOS (BSM). Roteiro do Programa de Qualificação Operacional — Edição 2025. São Paulo: BSM, 2025. Disponível em: <bsm.org.br/informacoes-de-autorregulacao/qualificacao-operacional>.

BRASIL. Lei 9.613, de 3 de março de 1998. Dispõe sobre os crimes de lavagem ou ocultação de bens, direitos e valores. Brasília: Presidência da República, 1998.

BRASIL. Lei 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília: Presidência da República, 2018.

COMISSÃO DE VALORES MOBILIÁRIOS (CVM). Resolução CVM 30, de 11 de maio de 2021a. Dispõe sobre o dever de verificação da adequação dos produtos (suitability). Rio de Janeiro: CVM.

COMISSÃO DE VALORES MOBILIÁRIOS (CVM). Resolução CVM 32, de 19 de maio de 2021b. Dispõe sobre a prestação de serviços de custódia de valores mobiliários. Rio de Janeiro: CVM.

COMISSÃO DE VALORES MOBILIÁRIOS (CVM). Resolução CVM 35, de 26 de maio de 2021c. Dispõe sobre as normas e procedimentos a serem observados nas operações realizadas em mercados regulamentados. Rio de Janeiro: CVM.

COMISSÃO DE VALORES MOBILIÁRIOS (CVM). Resolução CVM 50, de 31 de agosto de 2021d. Dispõe sobre a prevenção à lavagem de dinheiro no mercado de valores mobiliários. Rio de Janeiro: CVM.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.193, de 1º de março de 2013. Apuração dos requerimentos mínimos de Patrimônio de Referência (PR). Brasília: CMN.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.553, de 30 de janeiro de 2017b. Segmentação prudencial das instituições financeiras (S1 a S5). Brasília: CMN.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.557, de 23 de fevereiro de 2017a. Estrutura de gerenciamento contínuo e integrado de riscos e capital. Brasília: CMN.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.860, de 23 de outubro de 2020. Componente organizacional de Ouvidoria. Brasília: CMN.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.893, de 26 de fevereiro de 2021b. Política de segurança cibernética e requisitos para contratação de processamento e armazenamento em nuvem. Brasília: CMN.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.943, de 15 de setembro de 2021a. Sistema de controles internos das instituições financeiras. Brasília: CMN.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN 4.966, de 25 de novembro de 2021c. Conceitos e critérios contábeis aplicáveis a instrumentos financeiros e provisões. Brasília: CMN.

INSTITUTE OF INTERNAL AUDITORS (IIA). The IIA's three lines model: an update of the three lines of defense. Altamonte Springs: IIA, julho 2020.

Anexo A — Esquema dos Books

Esta seção apresenta o esquema completo dos Books do BooX. Cada tabela corresponde a um arquivo CSV da instância. A coluna "Categoria" indica se o campo é obrigatório, recomendado ou opcional segundo o protocolo descrito nas Seções 5 e 7. A coluna "Tipo" indica o tipo de dado esperado; os valores "lista" referem-se a enumerações cujos valores aceitos são apresentados no Anexo B.

B1 — Processos

Todos os processos do banco (P0->P4). Eixo estrutural do BooX.

Arquivo: `B1_processos.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do processo (ex: P.CRE.PF)
`nome`	Obrigatório	texto	Nome do processo
`nivel`	Obrigatório	int	Nivel hierarquico 0 a 4
`area_responsavel`	Obrigatório	texto	Area dona do processo (mapeia ao organizacional canonico)
`parent_id`	Recomendado	texto	ID do processo pai (vazio so para P0)
`nucleo`	Recomendado	lista (nucleo)	Valores possíveis: ver Anexo B, enum `nucleo`.
`criticidade_bia`	Recomendado	int	Criticidade BIA 1 a 5
`descricao`	Opcional	texto	O que o processo faz
`entrada`	Opcional	texto	Inputs (IPSO)
`saida`	Opcional	texto	Outputs (IPSO)
`data_revisao`	Opcional	data	Ultima revisao (AAAA-MM-DD)
`frequencia_execucao`	Opcional	lista (freq_proc)	Valores possíveis: ver Anexo B, enum `freq_proc`.
`volume_transacional`	Opcional	num	Volume medio de transacoes

B6 — Riscos (taxonomia)

Riscos no vocabulario do banco. Mapeiam a um R0 canonico via B_MAP. Mundo INERENTE.

Arquivo: `B6_riscos.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do risco local (ex: RL-07)
`nome`	Obrigatório	texto	Nome local do risco
`nivel`	Recomendado	int	Nivel hierarquico 0 a 4
`parent_id`	Recomendado	texto	ID do risco pai
`disciplina_id`	Recomendado	texto	Disciplina associada (ref. B9)
`descricao`	Opcional	texto	Descricao do risco
`categoria_basileia`	Opcional	texto	Categoria Basileia

B6 — Vinculo Processo x Risco

Cada linha = um par avaliavel = uma bolha no 20-box. Mundo INERENTE.

Arquivo: `B6_vinculo_processo_risco.csv`

Campo	Categoria	Tipo	Descrição
`processo_id`	Obrigatório	texto	ID do processo (ref. B1)
`risco_id`	Obrigatório	texto	ID do risco (ref. B6)
`materialidade_inerente`	Obrigatório	int	Impacto inerente 1 a 5 (eixo Y)
`materialidade_declarada_por`	Recomendado	texto	Quem declarou (CRO, area)
`notas`	Opcional	texto	Observacoes

B2 — Apontamentos

Risco MATERIALIZADO. Afetado, gestor, prazo e criticidade vivem aqui.

Arquivo: `B2_apontamentos.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do apontamento
`titulo`	Obrigatório	texto	Titulo curto da falha
`severidade`	Obrigatório	lista (severidade)	Valores possíveis: ver Anexo B, enum `severidade`.
`status`	Obrigatório	lista (status_apont)	Valores possíveis: ver Anexo B, enum `status_apont`.
`risco_id`	Obrigatório	texto	Risco relacionado (ref. B6) — ao menos risco OU processo
`data_abertura`	Obrigatório	data	Data de abertura (AAAA-MM-DD)
`area_afetada`	Obrigatório	texto	Quem sofre o impacto da falha
`area_gestora`	Obrigatório	texto	Quem responde pela correcao
`processo_id`	Recomendado	texto	Processo apontado (ref. B1)
`origem`	Recomendado	lista (origem)	Valores possíveis: ver Anexo B, enum `origem`.
`data_prazo`	Recomendado	data	Prazo de remediacao
`responsavel`	Recomendado	texto	Responsavel pela remediacao
`recorrencia`	Recomendado	lista (recorrencia)	Valores possíveis: ver Anexo B, enum `recorrencia`.
`descricao`	Opcional	texto	Descricao do apontamento
`controle_id`	Opcional	texto	Controle que falhou (ref. B5)
`data_fechamento`	Opcional	data	Data de fechamento (se status=fechado)
`plano_acao`	Opcional	texto	Plano de acao
`valor_perda`	Opcional	num	Perda financeira materializada (R$)

B5 — Controles (5W2H)

Controles que mitigam riscos. Eficacia puxa o eixo X (ambiente).

Arquivo: `B5_controles.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do controle
`acao`	Obrigatório	texto	What: o que o controle faz
`risco_id`	Obrigatório	texto	Why: risco mitigado (ref. B6)
`eficacia_autoavaliada`	Obrigatório	int	Eficacia 1 a 5 (autoavaliacao 1a linha)
`processo_id`	Recomendado	texto	Where: processo onde opera (ref. B1)
`eficacia_validada`	Recomendado	int	Eficacia 1 a 5 (validacao 2a linha)
`status_validacao`	Recomendado	lista (status_val)	Valores possíveis: ver Anexo B, enum `status_val`.
`natureza`	Recomendado	lista (natureza)	Valores possíveis: ver Anexo B, enum `natureza`.
`frequencia`	Recomendado	lista (freq_ctrl)	Valores possíveis: ver Anexo B, enum `freq_ctrl`.
`responsavel`	Recomendado	texto	Who: quem executa
`local`	Opcional	texto	Where: sistema/comite
`mecanismo`	Opcional	lista (mecanismo)	Valores possíveis: ver Anexo B, enum `mecanismo`.
`como`	Opcional	texto	How: descricao da operacao
`cobertura_pct`	Opcional	num	How much: % de operacoes cobertas
`tipo`	Opcional	lista (tipo_ctrl)	Valores possíveis: ver Anexo B, enum `tipo_ctrl`.
`data_ultimo_teste`	Opcional	data	Ultimo teste do controle
`custo`	Opcional	num	Custo do controle
`automatizavel`	Opcional	bool	Oportunidade de automacao (true/false)

B10 — Indicadores (KRIs)

KRIs de risco operacional. Trazem dinamica (tendencia).

Arquivo: `B10_indicadores.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do KRI
`nome`	Obrigatório	texto	Nome do indicador
`direcao`	Obrigatório	lista (direcao)	Valores possíveis: ver Anexo B, enum `direcao`.
`risco_id`	Obrigatório	texto	Risco monitorado (ref. B6) — ao menos risco OU processo
`limite_amarelo`	Recomendado	num	Limiar de alerta amarelo
`limite_vermelho`	Recomendado	num	Limiar critico vermelho
`processo_id`	Recomendado	texto	Processo monitorado (ref. B1)
`disciplina_id`	Recomendado	texto	Disciplina (ref. B9)
`unidade`	Recomendado	texto	Unidade (%, R$, contagem, dias)
`descricao`	Opcional	texto	O que mede
`meta`	Opcional	num	Meta do indicador
`responsavel_apuracao`	Opcional	texto	Quem calcula o KRI
`fonte_dado`	Opcional	texto	De onde vem o numero
`frequencia_apuracao`	Opcional	lista (freq_ctrl)	Valores possíveis: ver Anexo B, enum `freq_ctrl`.

B10 — Serie temporal dos KRIs

Valores mensais. Minimo 3 meses para calcular tendencia.

Arquivo: `B10_indicador_serie.csv`

Campo	Categoria	Tipo	Descrição
`indicador_id`	Obrigatório	texto	ID do KRI (ref. B10_indicadores)
`competencia`	Obrigatório	texto	Mes de referencia (AAAA-MM)
`valor`	Obrigatório	num	Valor observado

B8 — Externos, Ouvidoria e SAC

Sinais externos publicos + manifestacoes de cliente (Ouvidoria, SAC).

Arquivo: `B8_externos.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do sinal
`fonte`	Obrigatório	lista (fonte_ext)	Valores possíveis: ver Anexo B, enum `fonte_ext`.
`tipo`	Obrigatório	texto	Tipo do sinal (depende da fonte)
`data`	Obrigatório	data	Data de referencia (AAAA-MM-DD)
`risco_id`	Recomendado	texto	Risco associado (ref. B6) — risco OU disciplina
`disciplina_id`	Recomendado	texto	Disciplina associada (ref. B9)
`quantidade`	Recomendado	num	Quantidade (ex: nro de procedentes)
`severidade`	Recomendado	int	Severidade 1 a 5 (para midia)
`descricao`	Opcional	texto	Descricao do sinal
`processo_id`	Opcional	texto	Processo associado (ref. B1)
`status`	Opcional	texto	Ex: procedente, improcedente, julgado, em_curso
`valor_metrica`	Opcional	num	Valor de metrica continua (ex: nota)
`valor_anterior`	Opcional	num	Valor anterior (tendencia)
`periodo`	Opcional	texto	Periodo de referencia (ex: 2025-Q4)

B4 — Regulacao

Normas externas aplicaveis. Contexto e rastreabilidade na v0.1.

Arquivo: `B4_regulacao.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID da norma (ex: RES_CMN_4557)
`regulador`	Obrigatório	texto	Regulador emissor (CMN, BCB, CVM...)
`numero`	Obrigatório	texto	Numero da norma
`status`	Obrigatório	lista (status_norma)	Valores possíveis: ver Anexo B, enum `status_norma`.
`tipo`	Recomendado	texto	lei, res_cmn, res_bcb, circ_bcb, inst_cvm...
`titulo`	Recomendado	texto	Titulo da norma
`ano`	Recomendado	int	Ano de publicacao
`ementa`	Opcional	texto	Ementa/resumo
`url_oficial`	Opcional	texto	Link para o texto oficial

B4 — Vinculo de normas

Liga normas a processos e riscos.

Arquivo: `B4_vinculo_norma.csv`

Campo	Categoria	Tipo	Descrição
`norma_id`	Obrigatório	texto	Norma (ref. B4)
`alvo_tipo`	Obrigatório	lista (alvo_tipo)	Valores possíveis: ver Anexo B, enum `alvo_tipo`.
`alvo_id`	Obrigatório	texto	ID do processo (B1) ou risco (B6)
`tipo_vinculo`	Opcional	texto	primaria, secundaria, informativa
`notas`	Opcional	texto	Observacoes

B9 — Disciplinas

Disciplinas de risco transversais. Dimensao de corte.

Arquivo: `B9_disciplinas.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico (ex: DISC_CREDITO)
`nome`	Obrigatório	texto	Nome da disciplina
`responsavel_2linha`	Recomendado	texto	Area de 2a linha que monitora
`descricao`	Opcional	texto	Escopo da disciplina
`categoria_basileia`	Opcional	texto	Categoria Basileia

B7 — Visoes

Recortes que o CRO quer enxergar. Configuracao, nao dado.

Arquivo: `B7_visoes.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico da visao
`nome`	Obrigatório	texto	Nome legivel
`tipo`	Obrigatório	lista (tipo_visao)	Valores possíveis: ver Anexo B, enum `tipo_visao`.
`descricao`	Opcional	texto	O que mostra e por que
`owner`	Opcional	texto	Quem mantem
`regra_afetacao`	Opcional	texto	afetada ou gestora (para visao por area)

B7 — Filtros das visoes

Criterios de filtro de cada visao.

Arquivo: `B7_visao_filtros.csv`

Campo	Categoria	Tipo	Descrição
`visao_id`	Obrigatório	texto	Visao (ref. B7_visoes)
`dimensao`	Obrigatório	texto	processo, risco, disciplina, segmento, area...
`operador`	Obrigatório	lista (operador)	Valores possíveis: ver Anexo B, enum `operador`.
`valor`	Obrigatório	texto	Valor do filtro (ID ou lista com |)

B_TESTES — Testes regulamentares canonicos

Catalogo canonico de testes exigidos pelos reguladores. Camada CANONICA.

Arquivo: `B_TESTES_canonico.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do teste (ex: TST.BSM.PQO.CAD.001)
`regulador`	Obrigatório	texto	Regulador emissor (BACEN, CVM, SUSEP, BSM, ANBIMA, COAF)
`norma_id`	Obrigatório	texto	Norma originaria (ChassiRO ou local)
`titulo`	Obrigatório	texto	Titulo curto do teste
`aplicabilidade`	Obrigatório	texto	Tipos de instituicao (lista com |)
`artigo`	Recomendado	texto	Artigo/item da norma
`descricao`	Recomendado	texto	O que o teste verifica
`metodo_verificacao`	Recomendado	lista (metodo_verificacao)	Valores possíveis: ver Anexo B, enum `metodo_verificacao`.
`evidencia_esperada`	Recomendado	texto	Que evidencia comprova
`frequencia_minima`	Recomendado	texto	diario, mensal, trimestral, por_evento
`criticidade`	Recomendado	lista (criticidade_teste)	Valores possíveis: ver Anexo B, enum `criticidade_teste`.
`risco_r0_canonico`	Recomendado	texto	R0 canonico associado
`fator_risco_canonico_id`	Recomendado	texto	FR canonico (ref. B_FR_canonico)
`controle_esperado_texto`	Recomendado	texto	Descricao do controle-alvo exigido
`status`	Obrigatório	lista (status_teste_canonico)	Valores possíveis: ver Anexo B, enum `status_teste_canonico`.

Campo	Categoria	Tipo	Descrição
`substituido_por`	Opcional	texto	ID substituto (se deprecado)
`data_publicacao`	Opcional	data	Quando o teste entrou no catalogo
`fonte_url`	Opcional	texto	URL da norma oficial

B_FR — Fatores de Risco canonicos

Biblioteca canonica de Fatores de Risco (causas-raiz). Camada CANONICA.

Arquivo: `B_FR_canonico.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico do FR (ex: FR.CYBER.001)
`nome`	Obrigatório	texto	Nome do fator de risco
`risco_canonico_id`	Obrigatório	texto	Risco canonico associado (ref. B6_riscos_canonico)
`descricao`	Recomendado	texto	Descricao da causa-raiz
`categoria`	Recomendado	texto	pessoa | processo | sistema | evento_externo
`status`	Obrigatório	lista (status_teste_canonico)	Valores possíveis: ver Anexo B, enum `status_teste_canonico`.
`substituido_por`	Opcional	texto	ID substituto (se deprecado)

B_TESTES_execucao — Execucao dos testes pelo banco

Camada LOCAL: quais testes canonicos o banco executa, com resultado.

Arquivo: `B_TESTES_execucao.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico da execucao
`teste_canonico_id`	Obrigatório	texto	ID do teste canonico
`controle_id`	Obrigatório	texto	Controle real do banco (ref. B5)
`resultado_ultimo`	Obrigatório	lista (resultado_teste)	Valores possíveis: ver Anexo B, enum `resultado_teste`.
`data_ultimo`	Obrigatório	data	Data da ultima execucao
`executado_por`	Recomendado	texto	Papel/area responsavel
`evidencia_id`	Recomendado	texto	Referencia a evidencia (B_EVIDENCIA)
`frequencia_real`	Recomendado	texto	Com que frequencia o banco executa
`apontamento_id`	Opcional	texto	Apontamento se nao_conforme (ref. B2)
`observacoes`	Opcional	texto	Notas da execucao

B_EVIDENCIA — Evidencias de atendimento

Camada LOCAL: catalogo das evidencias do banco para cada teste.

Arquivo: `B_EVIDENCIA.csv`

Campo	Categoria	Tipo	Descrição
`id`	Obrigatório	texto	ID unico da evidencia
`tipo`	Obrigatório	texto	log|ata|relatorio|print|politica|procedimento|outros
`titulo`	Obrigatório	texto	Titulo/nome da evidencia
`data`	Obrigatório	data	Data da evidencia
`local`	Recomendado	texto	Onde esta armazenada
`responsavel`	Recomendado	texto	Custodio/responsavel
`descricao`	Opcional	texto	Descricao adicional
`hash`	Opcional	texto	Hash de integridade

Anexo B — Enumerações (enums)

Valores admitidos para os campos de tipo "lista" nos Books. Qualquer valor diferente dos listados é considerado inválido pela engine de suficiência.

Nome do enum	Valores admitidos
alvo_tipo	processo, risco
criticidade_teste	alta, media, baixa
direcao	menor_melhor, maior_melhor
fonte_ext	bacen, cvm, anbima, procon, midia, reclame_aqui, ouvidoria, sac
freq_ctrl	continuo, diario, semanal, mensal, trimestral, semestral, anual, por_evento, sob_demanda
freq_proc	continuo, diario, semanal, mensal, trimestral, semestral, anual, por_evento
mecanismo	manual, semi, automatico
metodo_verificacao	revisao_documental, teste_amostral, observacao, reexecucao, entrevista, analitico, automatizado
natureza	preventivo, detectivo, corretivo
nucleo	U, B, MC, S, P, C, CG
operador	igual, prefixo, em, descendente_de
origem	controles_internos, auditoria, compliance, gestao, regulador
recorrencia	primeira, reincidente
resultado_teste	nao_executado, conforme, nao_conforme, parcialmente_conforme, na
severidade	critico, alto, medio, baixo
status_apont	aberto, em_tratamento, vencido, fechado
status_norma	vigente, revogada, futura
status_teste_canonico	ativo, deprecado, proposto
status_val	apenas_autoavaliado, validado_documentalmente, validado_amostral, validado_completo
tipo_ctrl	icaap, operacional, credito, cobranca, mercado, liquidez, compliance, outro
tipo_instituicao	banco_multiplo, banco_comercial, corretora, dtvm, distribuidora, seguradora, previdencia, capitalizacao, cooperativa, consorcio, administrador_fiduciario, gestor_recursos, fintech_pagamentos, instituicao_pagamento, fintech_credito
tipo_visao	produto, processo, e2e, disciplina, area, livre

Anexo C — Comandos de linha de comando

Esta seção consolida os comandos de linha de comando utilizados na operação diária do BooX. Os comandos pressupõem que o pacote `boox-ro` está instalado, seja via instalação local do repositório (`pip install .` executado na raiz do projeto), seja via índice interno (Artifactory ou Nexus corporativo). A instalação cria dois executáveis no ambiente Python: `boox` e `boox-gap`. A instalação com extras habilita o aplicativo Streamlit, com o executável adicional `boox-app`.

C.1 Instalação

Instalação mínima, somente da engine de cálculo (sem dependências externas):

```
pip install .
```

Instalação com o gerador de templates Excel:

```
pip install ".[templates]"
```

Instalação com o aplicativo Streamlit:

```
pip install ".[app]"
```

Instalação em ambiente corporativo com índice interno (exemplo com Nexus):

```
pip install --index-url https://nexus.seu-banco.local/pypi/simple boox-ro
```

C.2 Execução do cálculo principal

Executar o cálculo do 20-box para a instância informada:

```
boox <pasta_instancia> --out <pasta_saida>
```

Executar em modo ar-gapped (sem rede, com bloqueio ativo de sockets):

```
boox <pasta_instancia> --out <pasta_saida> --air-gapped
```

Executar com filtro por visão analítica (as visões são definidas em B7):

```
boox <pasta_instancia> --out <pasta_saida> --visao VIS_CONSIGNADO
```

A execução produz quatro arquivos na pasta de saída: `20box.html`, `detalhamento.csv`, `parecer.md` e `suficiencia.md`. Quando a opção `--air-gapped` é informada, a engine verifica o ambiente e emite alerta caso qualquer proxy HTTP esteja definido; adicionalmente, a engine intercepta chamadas de rede em tempo de execução e aborta caso alguma seja tentada.

C.3 Execução da análise de gap regulatório

Analisar o gap regulatório para um tipo específico de instituição:

```
boox-gap <pasta_instancia> --tipo corretora --out gap_regulatorio.md
```

Os valores admitidos para `--tipo` são listados no enum `tipo_instituicao` do Anexo B. Quando o argumento é omitido, a análise considera todos os testes aplicáveis, sem filtro de tipo.

C.4 Curadoria do canônico

Listar o conteúdo de um domínio canônico (riscos, áreas, domínios, disciplinas, fatores, testes):

```
python canonico/curar.py listar riscos
```

Adicionar um novo risco canônico (incrementa versão minor):

```
python canonico/curar.py adicionar riscos --id R0.U.22 --nome "Nome do risco" \
    --campos categoria_basileia=operacional grupo=operacional descricao="Descrição
do risco"
```

Renomear o rótulo de um identificador existente (incrementa versão patch):

```
python canonico/curar.py renomear riscos --id R0.U.22 --nome "Novo nome do risco"
```

Deprecar um identificador em uso, apontando o substituto (incrementa versão major):

```
python canonico/curar.py deprecar riscos --id R0.U.22 --substituido_por R0.U.6
```

Validar a integridade referencial do canônico (executar sempre após operação de curadoria):

```
python canonico/validar.py
```

C.5 Aplicativo Streamlit

Iniciar o aplicativo de demonstração localmente:

```
boox-app
```

Equivalente a `streamlit run boox/app_streamlit.py`. O aplicativo inicia um servidor local em `http://localhost:8501`. A instância padrão apresentada é a do Banco Modelo S.A. (dados fictícios); a interface permite carregar os Books próprios por meio de upload múltiplo de CSVs na barra lateral.

C.6 Geração de templates Excel

Os templates Excel para preenchimento assistido são gerados pelo utilitário em `templates/_gerar_templates.py`. Cada Book tem seu próprio arquivo com as colunas coloridas por categoria (obrigatório, recomendado, opcional), listas suspensas para os campos de enumeração, e uma aba de instruções com a descrição de cada campo.

```
python templates/_gerar_templates.py
```

> ***Encerramento.*** Este manual descreve a versão do BooX canônico 1.1.1 e framework 0.2. Atualizações subsequentes do framework são documentadas em `CHANGELOG.md` no repositório. Correções, sugestões de aprimoramento ou propostas de inclusão de novos reguladores no catálogo canônico podem ser submetidas via issues no repositório público do BooX.